

Adena Security Evaluation Feb 2024



[Executive Summary](#)

[Scope](#)

[Methodology](#)

[Findings](#)

[Medium](#)

[Low](#)

[Informational](#)

[Appendices](#)

[Appendix I: Installation](#)

[Appendix II: Screenshots of Application Functionality](#)

[Appendix III: Ledger device send approval flow](#)

[Appendix III: Analysis Artifacts](#)

[Appendix IV: Yarn/NPM Audit Results](#)

[Appendix V: Domains and URLs Accessed](#)

[Future Areas for Review](#)

Executive Summary

AiB's Security Engineering conducted an informal, time-boxed security evaluation of OnBloc's Adena wallet between February 13 and February 16, 2024.

The evaluation identified potential security issues, as summarized in the following table:

Severity	# Findings (Open Acknowledged Blocked)
Medium	1
Low	0
Informational	2

Table last updated 2024/04/23.

OnBloc has reviewed these findings and closed several of them, as documented here:

https://docs.google.com/document/d/1Gucq4DEeCzFGqGTvPY8dCA3tZZPLWu__p5lI86gLuWA/edit

Scope

Evaluation was based on: <https://github.com/onbloc/adena-wallet/releases/tag/v1.9.0-rc.0>

Source code link: <https://github.com/onbloc/adena-wallet/tree/925cb4f44cb6c438e7705c5ecc535ee5ddf307e0>

Adena is described as follows within the README:

Adena is a friendly, open-source, non-custodial Gnoland wallet, built for Gnomes worldwide. Adena exists to power millions of realms (smart

contracts in golang) and tokens that will flourish the Gnoland ecosystem with a quality interface, NFT & custom token support, and a seamless integration procedure.

For users, Adena makes managing crypto as simple as keeping and sending money on Paypal or Venmo.

For developers, Adena provides streamlined web3 experience upon integration!

Features

- ☒ Create & Restore Wallet
- ☒ View Account Balances
- ☒ Deposit & Send Tokens
- ☒ Transaction History
- ☒ Settings
- ☒ Connect to Dapps
- ☒ Sign GNO Contracts
- ☒ Explore Dapps
- ☒ Multi-Accounts
- ☒ Multi-Network
- ☒ Ledger Support
- ☒ Web3 Login Support
- ☒ Manage Custom Tokens
- ☐ Airgap Support
- ☐ Multi-Chain
- ☐ View & Transfer NFTs
- ☐ In-app Swap

Methodology

Evaluation consisted of manual code review, automated code analysis using GitHub’s CodeQL and Dependabot tools, automated dynamic testing using Burp Suite, and manual dynamic testing interacting with the browser extension.

Findings

The following findings were identified, categorized by subjective severity.

ID	Title	Status
MEDIUM-001	Lack of Hardware Wallet Device Confirmation of Public Keys/Addresses	Acknowledged
LOW-001	Weak Password Complexity Feedback	Closed
LOW-002	Address Book Data Stored in Plaintext	Closed
LOW-003	Strict Transport Security Not Enforced	Closed

ID	Title	Status
INFO-001	Telemetry not disabled in Yarn	Closed (v1.10.1)
INFO-002	Weak password complexity requirements	Closed (v1.10.0)
INFO-003	The hyperlink to the terms of use on the password selection screen is not visible	Closed
INFO-004	Confusing Ledger Confirmation Screens	Closed
INFO-005	Outstanding Vulnerabilities in Dependencies	Closed
INFO-006	Static Fees	Blocked
INFO-007	Lack of Dependency Sandboxing	Acknowledged
INFO-008	Lack of Dependency Lifecycle Hook Whitelisting	Closed

Medium

- **MEDIUM-001: Lack of Hardware Wallet Device Confirmation of Public Keys/Addresses.**
When registering a Ledger hardware wallet with Adena and when fetching receiving addresses, the client does not interact with the device to confirm public keys and/or addresses. This step is necessary to prevent MITM attacks that might replace the user’s hardware wallet addresses with an attacker’s. **Note:** Use of the Ledger API to verify public keys and addresses is not yet common beyond the Ledger Live application.

Recommendation: Use the Ledger API to confirm public keys and addresses when registering a new hardware wallet, and any time the user elects to receive funds.

Status: Acknowledged by developer with plan to fix.

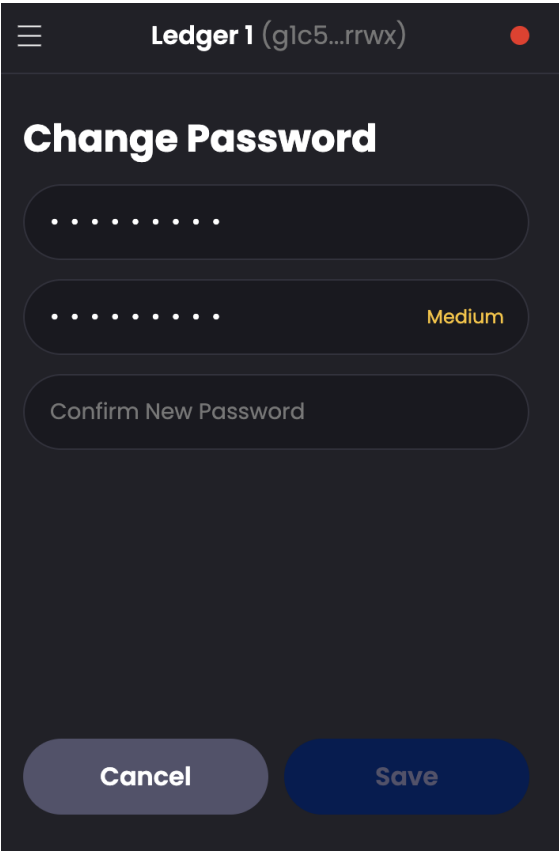
Low

- **LOW-001: Weak Password Complexity Feedback:** When a password of sufficient complexity is chosen by the user, a green checkmark is shown. However, the actual complexity of such passwords can be very low, such as “12345678”.

Recommendation: Consider the use of a complexity library such as <https://github.com/dropbox/zxcvbn> to provide more useful feedback to users about the strength of their passwords.

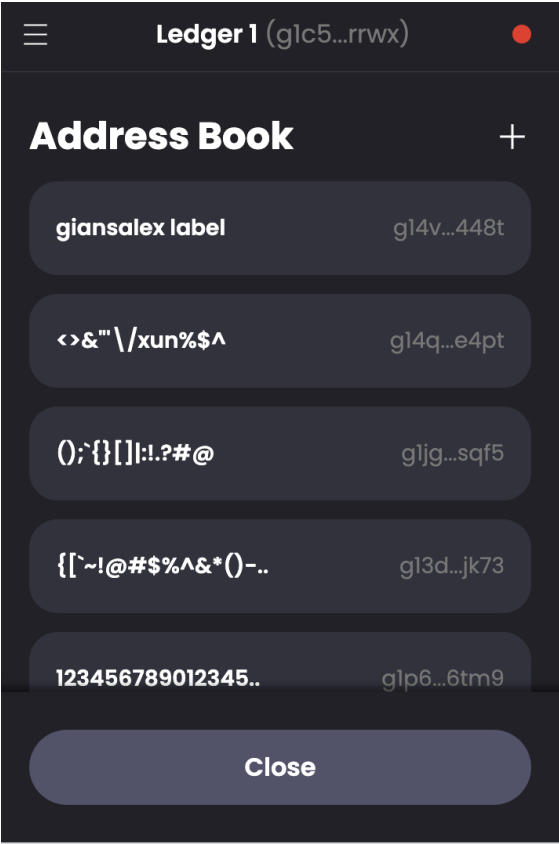
Status: Closed: This is now substantially mitigated; The wallet uses the zxcvbn library and rejects passwords with a score of 1 or lower (e.g. “abc1234”) and accepts passwords with a score of 2 or higher (e.g. “AbGc12345”) and marks score=2 passwords as “Medium” strength with an appropriate text color. This fix was applied in and validated using:

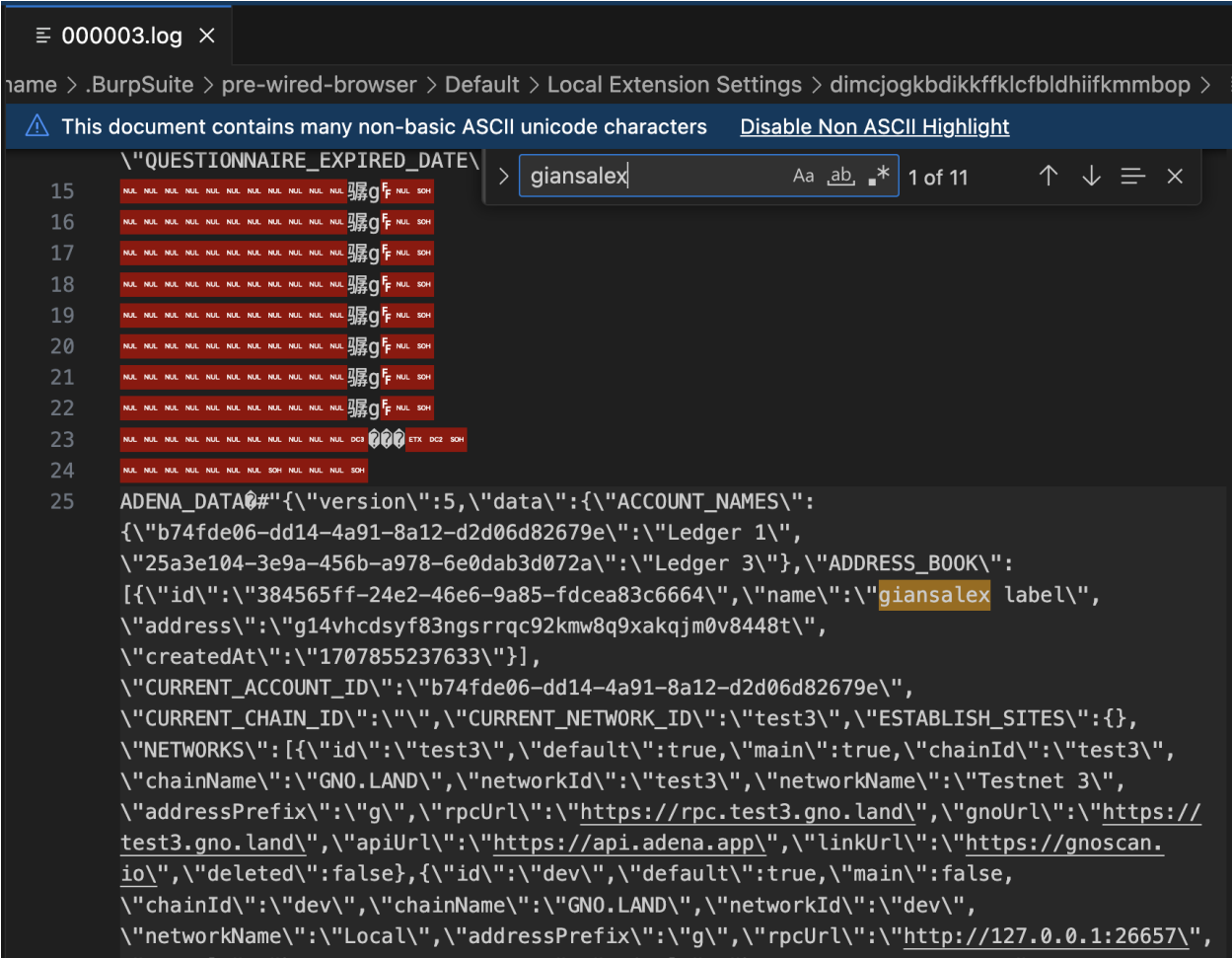
<https://github.com/onbloc/adena-wallet/releases/tag/v1.9.0-rc.1> and this tool: <https://lowe.github.io/tryzxcvbn/>



- **LOW-002:** Address Book Data Stored in Plaintext: Chrome logs are storing address book data from the user in plaintext. Users may expect that all such data is stored encrypted using BPKDF2 on-disk using their passwords.

Recommendation: Investigate whether improper logging may cause sensitive user data to be logged.

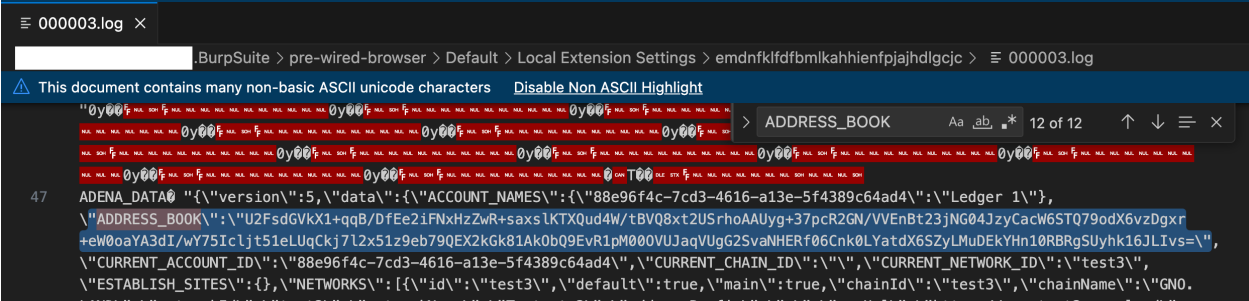




Plaintext information found in [Chrome data directory]/[Profile name]/Local Extension Settings/[identifier]/000003.log

Status: Closed: The address book data is now visibly encrypted by what appears to be the user's password using AES encryption. This fix was applied in <https://github.com/onbloc/adena-wallet/pull/402/files> and validated using:

<https://github.com/onbloc/adena-wallet/releases/tag/v1.9.0-rc.1>



- **LOW-003: Strict Transport Security Not Enforced:** The application fails to prevent users from connecting to it over unencrypted connections. An attacker able to modify a legitimate user's network traffic could bypass the application's use of SSL/TLS encryption, and use the application as a platform for attacks against its users. This attack is performed by rewriting HTTPS links as HTTP, so that if a targeted user follows a link to the site from an HTTP page, their browser never attempts to use an encrypted connection. The sslstrip tool automates this process.
To exploit this vulnerability, an attacker must be suitably positioned to intercept and modify the victim's network traffic. This scenario typically occurs when a client communicates with the server over an insecure connection such as public Wi-Fi, or a corporate or home network that is shared with a compromised computer. Common defenses such as switched networks are not sufficient to prevent this. An attacker situated in the user's ISP or the application's hosting infrastructure could also perform this attack. Note that an advanced adversary could potentially target any connection made over the Internet's core infrastructure.

Recommendation: The application should instruct web browsers to only access the application using HTTPS. To do this, enable HTTP Strict Transport Security (HSTS) by adding a response header with the name ' `Strict-Transport-Security` ' and the value ' `max-age=expireTime` ', where `expireTime` is the time in seconds that browsers should remember that the site should only be accessed using HTTPS. Consider adding the ' `includeSubDomains` ' flag if appropriate. Note that because HSTS is a "trust on first use" (TOFU) protocol, a user who has never accessed the application will never have seen the HSTS header, and will therefore still be vulnerable to SSL stripping attacks. To mitigate this risk, you can optionally add the 'preload' flag to the HSTS header, and submit the domain for review by browser vendors.

```
GET /test3/multi_history/g1c5k6r9nlafv74uwlyewlplv9agquxhc5a3rrwx?from=0&s
Host: api.adena.app
=>
HTTP/2 200 OK
Date: Fri, 16 Feb 2024 17:44:46 GMT
Content-Type: application/json
Server: nginx/1.23.4
Vary: Origin
Access-Control-Allow-Origin: *

{
  ...
```

Status: Closed.

```
% curl -v "https://api.adena.app/test3/multi_history/g1c5k6r9nlafv74uwlyew
...
< HTTP/2 200
...
< strict-transport-security: max-age=31536000; includeSubDomains; preload
```

Informational

- **INFO-001: Telemetry not disabled in Yarn:** Yarn will periodically gather anonymous telemetry: <https://yarnpkg.com/advanced/telemetry>

Recommendation: Protect devs and consumers by disabling telemetry. To disable telemetry on a project (including for anyone who would clone it), run `yarn config set enableTelemetry 0` ; to audit status run `yarn config get enableTelemetry`

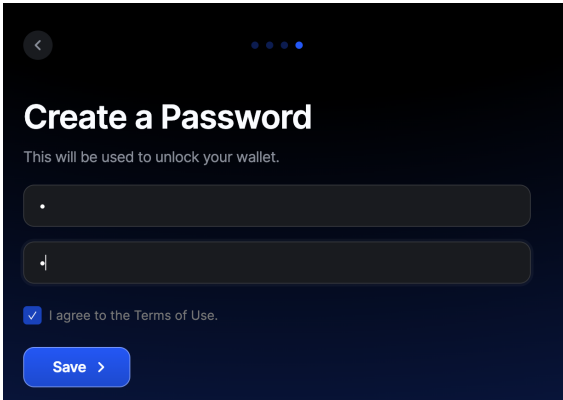
Status: Closed. This was addressed in the following commit: <https://github.com/onbloc/adena-wallet/commit/7028699465117df23255711c8c636e5c4c2c5e29>

- **INFO-002: Weak password complexity requirements.** The password selection screen to locally unlock the wallet makes a password mandatory and does not accept an empty field, but does accept weak passwords such as "12345678".

Recommendation: Allow users to bypass password selection optionally, or require passwords with meaningful complexity. See screenshot:

Status: Closed: This is now substantially mitigated; The wallet uses the zxcvbn library and rejects passwords with a score of 1 or lower (e.g. "abc1234") and accepts passwords with a score of 2 or higher (e.g. "AbGc12345") and marks score=2 passwords as "Medium" strength with an appropriate text color. This fix was applied in and validated using:

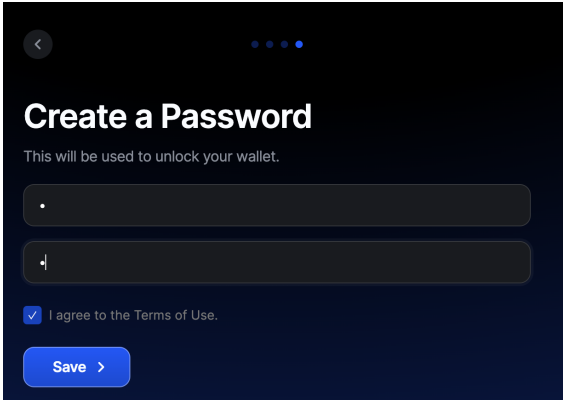
<https://github.com/onbloc/adena-wallet/releases/tag/v1.9.0-rc.1> and this tool:
<https://lowe.github.io/tryzxcvbn/>



- **INFO-003:** The hyperlink to the terms of use on the password selection screen is not visible.

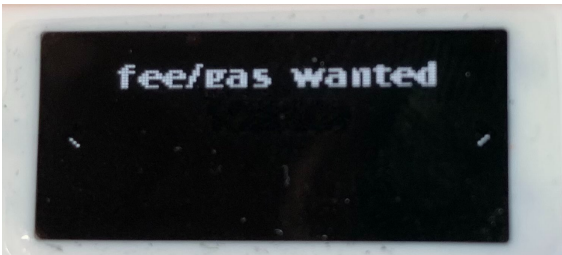
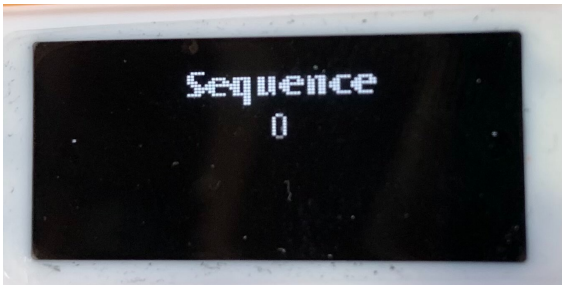
Recommendation: Make any clickable links on this screen underlined to emphasize that the terms can be fetched through clicking, avoiding user confusion. See screenshot:

Status: Closed.



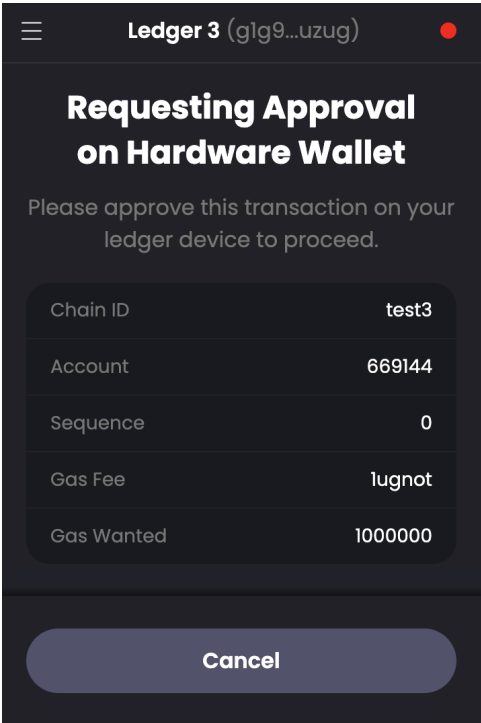
- **INFO-004: Confusing Ledger Confirmation Screens:** Data shown to the user on the Ledger device when confirming an outgoing transaction of GNOT is confusing, including the meaning of the integers shown on the "Account" and "Sequence" as well as the discrepancy between the "fee" vs. "fees wanted" values. When these screens are unclear to users, it may train them to skip validation of these fields or even skip validation of all fields altogether.

Recommendation: Add additional context to the client explaining what fields the user will see on the Ledger device, and how to validate them.



Status: Closed: Explanatory text added. This fix was applied in <https://github.com/onbloc/adena-wallet/pull/403> and validated using:

<https://github.com/onbloc/adena-wallet/releases/tag/v1.9.0-rc.1>



- **INFO-005: Outstanding Vulnerabilities in Dependencies:** GitHub Dependabot detected 22 vulnerabilities in Adena's dependency tree, including 5 at the Critical severity level. Validating exploitability of those findings was not in scope of this review.

Recommendation: Enable Dependabot alerts or a comparable product. Prioritize updating 1st-level dependencies, especially when a patch is available for vulnerabilities at the High or Critical level.

Status: Closed. While the specific vulnerabilities in the dep tree were not evaluated, OnBloc is now using Dependabot to manage this issue. This was supported in <https://github.com/onbloc/adena-wallet/pull/404>.

- **INFO-006: Static Fees:** Currently Adena does not appear to query a source of data about fee markets, and uses a hard-coded value of 0.000001 GNOT for sending funds. This is likely

practical during testnet conditions but may cause failed transactions during mainnet.

Recommendation: Prior to mainnet, adjust fees based on a source of data about fee market conditions.

Status: Blocked: This is not yet supported by gno.

- **INFO-007: Lack of Dependency Sandboxing:** The application's modules are loaded into a shared execution environment. A malicious dependency targeting the application can access sensitive user data. Consider a sandboxing framework such as Metamask's [Lavamoat](#) to implement the principle of least privilege between the application's modules.

Status: Acknowledged by developer with plan to fix.

- **INFO-008: Lack of Dependency Lifecycle Hook Whitelisting:** Malicious packages will often target dependent applications by including malicious install scripts. This can be mitigated by whitelisting specific install scripts, e.g. through <https://github.com/LavaMoat/LavaMoat/blob/main/packages/allow-scripts>

Status: Closed. This was addressed in the following commit included in v1.10.0:
<https://github.com/onbloc/adena-wallet/commit/79b4666c4a822adad82ea8a875bbd56c1a268fe7>

Appendices

Appendix I: Installation

The application is generally available through the Chrome extension store. However, OnBloc requested evaluation of a pre-release build.

Per the repo's [README.md](#), the application was built using these commands:

```
yarn install
yarn build
```

Build warnnigs:

```
YN0065: Yarn will periodically gather anonymous telemetry: https://yarnpkg.co
➤ YN0065: Run yarn config set --home enableTelemetry 0 to disable

➤ YN0000: └ Resolution step
➤ YN0002: | @web3auth/base-plugin@npm:7.1.0 doesn't provide @babel/runtime (
➤ YN0002: | adena-extension@workspace:packages/adena-extension doesn't provi
➤ YN0002: | adena-extension@workspace:packages/adena-extension doesn't provi
➤ YN0002: | adena-torus-signin@workspace:packages/adena-torus-signin doesn't
➤ YN0002: | adena-torus-signin@workspace:packages/adena-torus-signin doesn't
➤ YN0002: | adena-torus-signin@workspace:packages/adena-torus-signin doesn't
➤ YN0002: | adena-torus-signin@workspace:packages/adena-torus-signin doesn't
➤ YN0002: | adena-torus-signin@workspace:packages/adena-torus-signin doesn't
➤ YN0002: | adena-torus-signin@workspace:packages/adena-torus-signin doesn't
➤ YN0002: | adena-torus-signin@workspace:packages/adena-torus-signin doesn't
➤ YN0002: | adena-torus-signin@workspace:packages/adena-torus-signin doesn't
➤ YN0002: | adena-torus-signin@workspace:packages/adena-torus-signin doesn't
➤ YN0002: | adena-wallet@workspace:. doesn't provide react (p36f42), request
```

```

➤ YN0002: | adena-wallet@workspace:. doesn't provide react-dom (p5ae85), req
➤ YN0002: | adena-wallet@workspace:. doesn't provide webpack (p7062c), requ
➤ YN0002: | adena-wallet@workspace:. doesn't provide webpack (p8be20), requ
➤ YN0002: | eslint-config-react-app@npm:7.0.1 [0e9a1] doesn't provide @babel
➤ YN0002: | eslint-config-react-app@npm:7.0.1 [0e9a1] doesn't provide @babel
➤ YN0000: | Some peer dependencies are incorrectly met; run yarn explain pee
...
➤ YN0013: | yargs-parser@npm:21.1.1 can't be found in the cache and will be
➤ YN0013: | yargs@npm:16.2.0 can't be found in the cache and will be fetched
➤ YN0013: | yargs@npm:17.7.1 can't be found in the cache and will be fetched
➤ YN0013: | yauzl@npm:2.10.0 can't be found in the cache and will be fetched
➤ YN0013: | yocto-queue@npm:0.1.0 can't be found in the cache and will be fe
...
➤ YN0007: | protobufjs@npm:7.2.3 must be built because it never has been bef
➤ YN0007: | protobufjs@npm:7.2.2 must be built because it never has been bef
➤ YN0007: | esbuild@npm:0.17.16 must be built because it never has been befo
➤ YN0007: | core-js-pure@npm:3.30.0 must be built because it never has been
...
WARNING in asset size limit: The following asset(s) exceed the recommended si
This can impact web performance.
Assets:
  assets/account-added.gif (3.75 MiB)
  assets/add-account.gif (414 KiB)
  assets/gnoswap.svg (359 KiB)
  assets/waiting-for-google-login.gif (282 KiB)
  web.js (3.83 MiB)
  popup.js (3.36 MiB)
  background.js (2.53 MiB)
  inject.js (2.53 MiB)
  resources/fonts/inter.css (855 KiB)
  resources/apps/images/gnoland.svg (281 KiB)

WARNING in entrypoint size limit: The following entrypoint(s) combined asset
Entrypoints:
  web (3.83 MiB)
    web.js
  popup (3.36 MiB)
    popup.js
  background (2.53 MiB)
    background.js
  inject (2.53 MiB)
    inject.js

WARNING in webpack performance recommendations:
You can limit the size of your bundles by using import() or require.ensure to
For more info visit https://webpack.js.org/guides/code-splitting/

webpack 5.76.1 compiled with 3 warnings in 581975 ms
...
➤ YN0002: | @web3auth/base-plugin@npm:7.1.0 doesn't provide @babel/runtime (
➤ YN0002: | adena-extension@workspace:packages/adena-extension doesn't provi
➤ YN0002: | adena-extension@workspace:packages/adena-extension doesn't provi
➤ YN0002: | adena-torus-signin@workspace:packages/adena-torus-signin doesn't
➤ YN0002: | adena-torus-signin@workspace:packages/adena-torus-signin doesn't
➤ YN0002: | adena-torus-signin@workspace:packages/adena-torus-signin doesn't
➤ YN0002: | adena-torus-signin@workspace:packages/adena-torus-signin doesn't

```

```
➤ YN0002: | adena-torus-signin@workspace:packages/adena-torus-signin doesn't
➤ YN0002: | adena-torus-signin@workspace:packages/adena-torus-signin doesn't
➤ YN0002: | adena-torus-signin@workspace:packages/adena-torus-signin doesn't
➤ YN0002: | adena-torus-signin@workspace:packages/adena-torus-signin doesn't
➤ YN0002: | adena-wallet@workspace:. doesn't provide react (p36f42), request
➤ YN0002: | adena-wallet@workspace:. doesn't provide react-dom (p5ae85), req
➤ YN0002: | adena-wallet@workspace:. doesn't provide webpack (p7062c), reque
➤ YN0002: | adena-wallet@workspace:. doesn't provide webpack (p8be20), reque
➤ YN0002: | eslint-config-react-app@npm:7.0.1 [0e9a1] doesn't provide @babel
➤ YN0002: | eslint-config-react-app@npm:7.0.1 [0e9a1] doesn't provide @babel
➤ YN0000: | Some peer dependencies are incorrectly met; run yarn explain pee
```

The application was then loaded into Chromium in Developer mode as an unpacked extension by specifying the `packages/adena-extension/dist` directory containing `manifest.json`.

Appendix II: Screenshots of Application Functionality

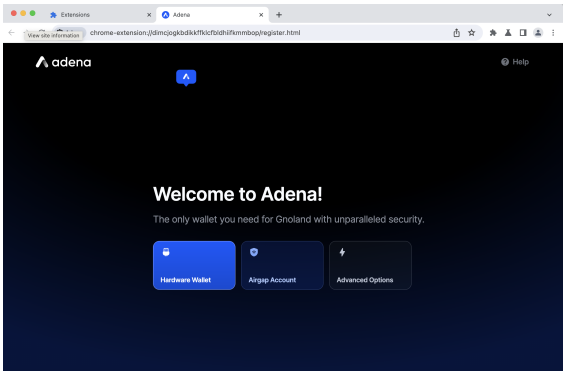


Figure 1: Loading screen after installing extension

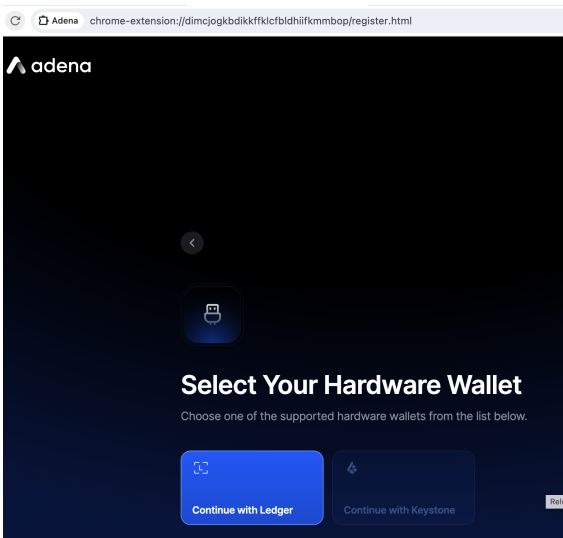


Figure 2: Hardware wallet selection. Keystone not selectable.

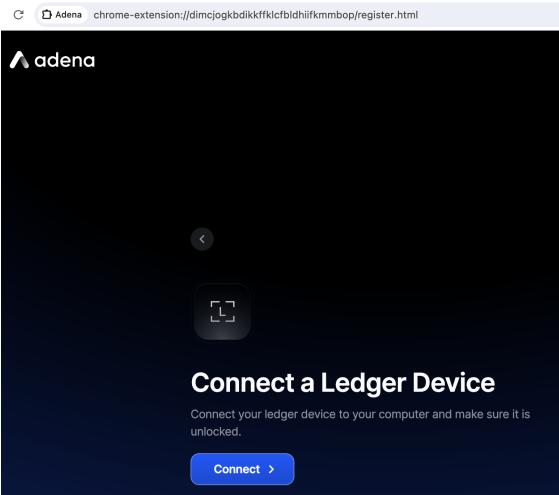


Figure 3: Ledger intro screen.

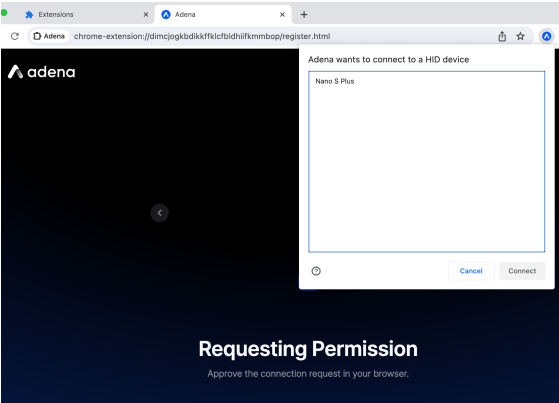


Figure 4: Requesting permissions via browser to HID device

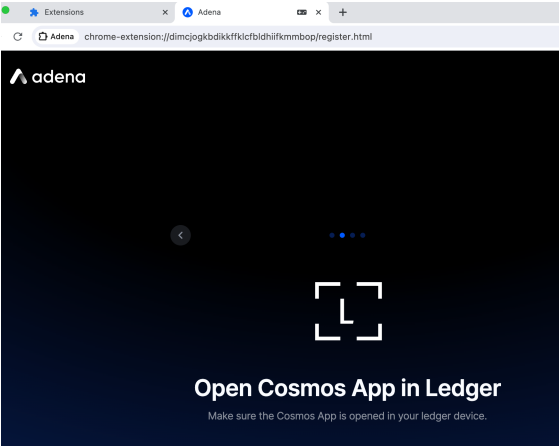


Figure 5: Informing user to open Cosmos App on Ledger device

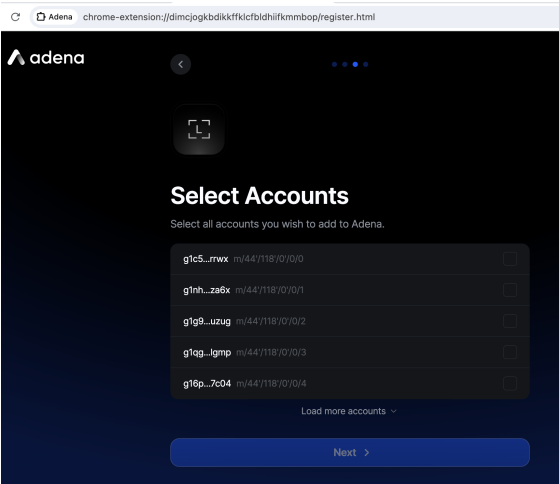


Figure 6: Ledger account selection screen

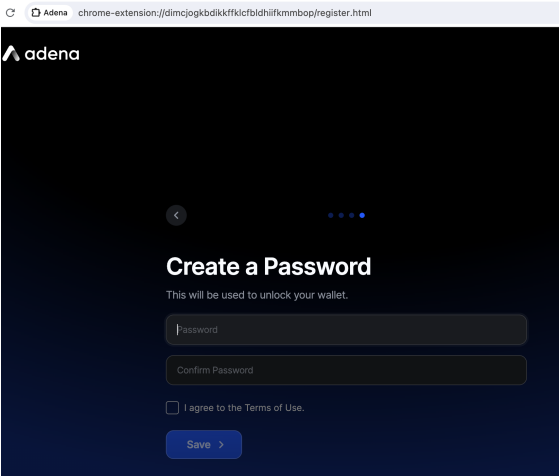


Figure 7: Password selection screen.

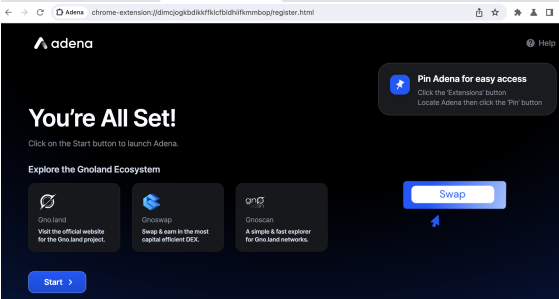


Figure 8: Landing screen after setting password

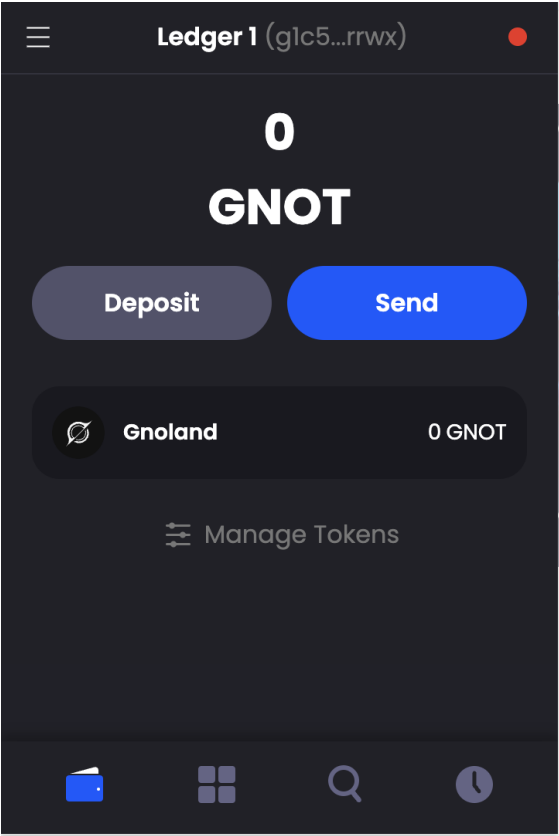


Figure 9: Main window inside extension

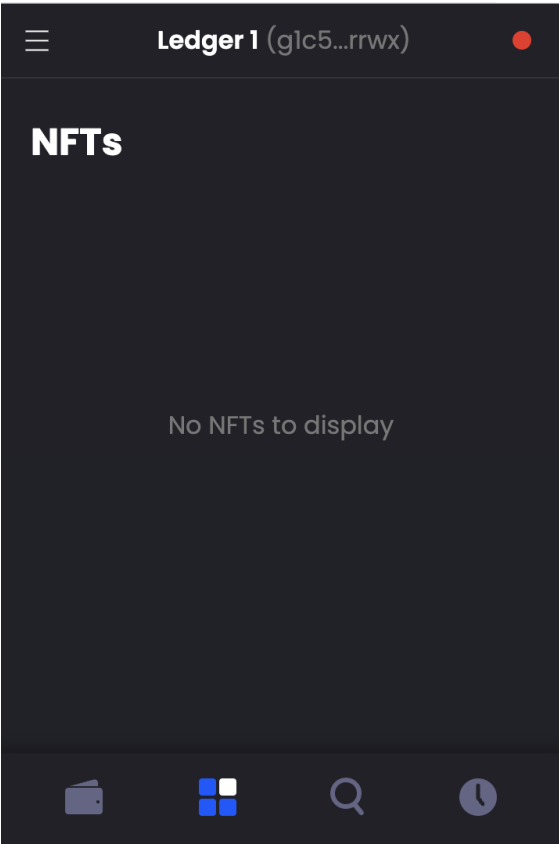


Figure 10: NFTs pane

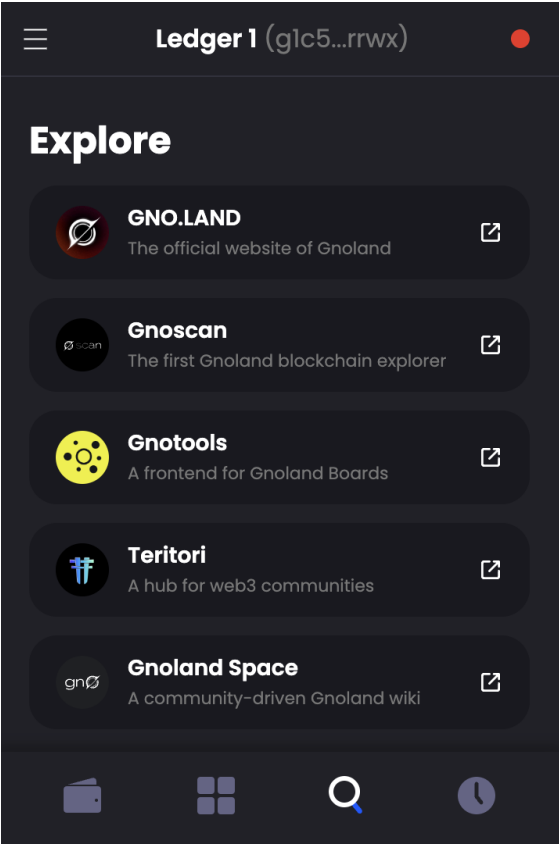


Figure 11: Explore pane

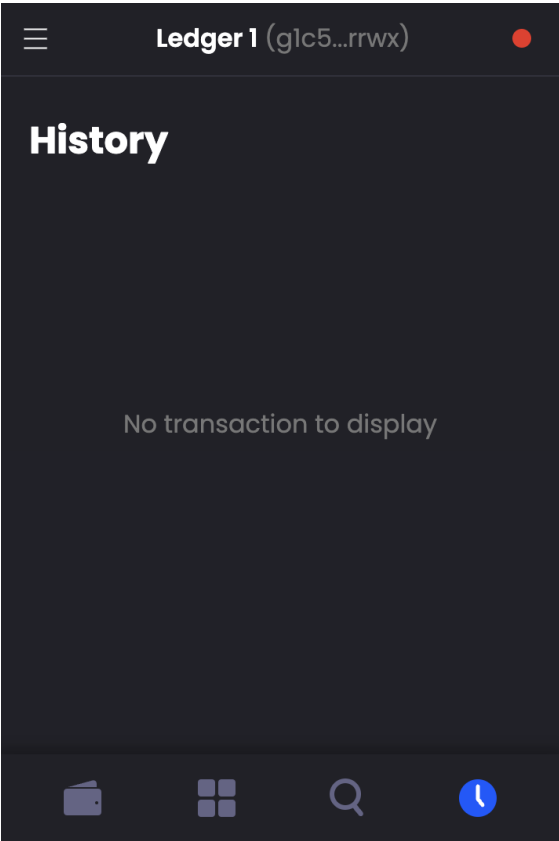


Figure 12: History pane

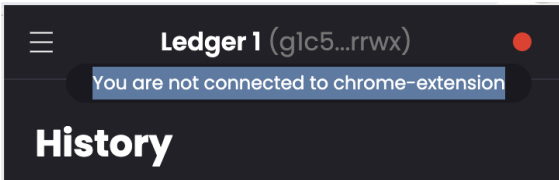


Figure 13: Dot connection indicator in top right corner, with tooltip explanation

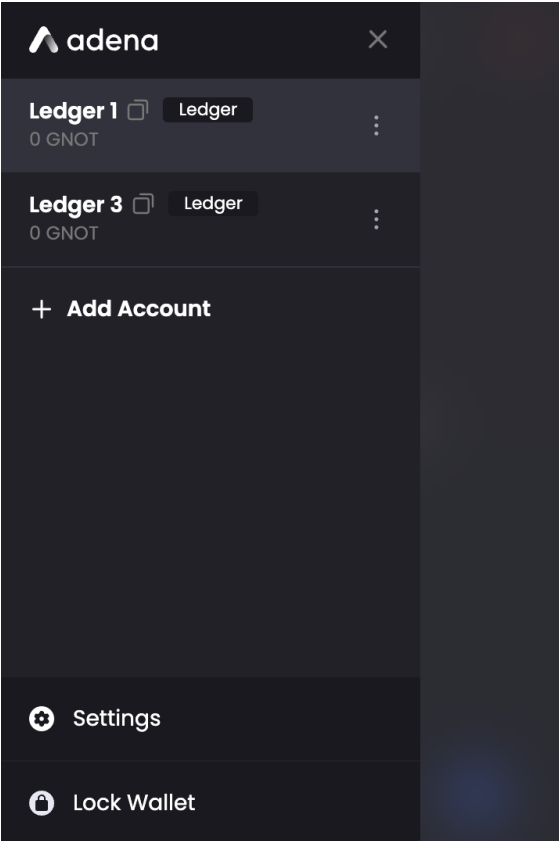


Figure 14: Hamburger menu

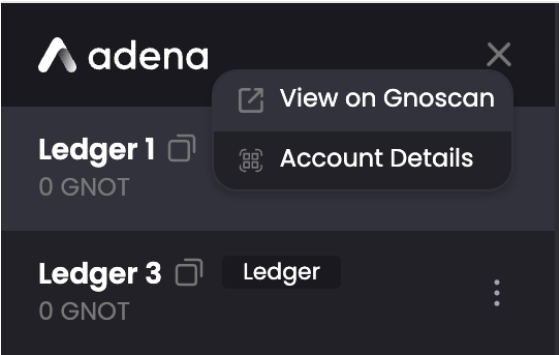


Figure 15: Account triple-dot menu

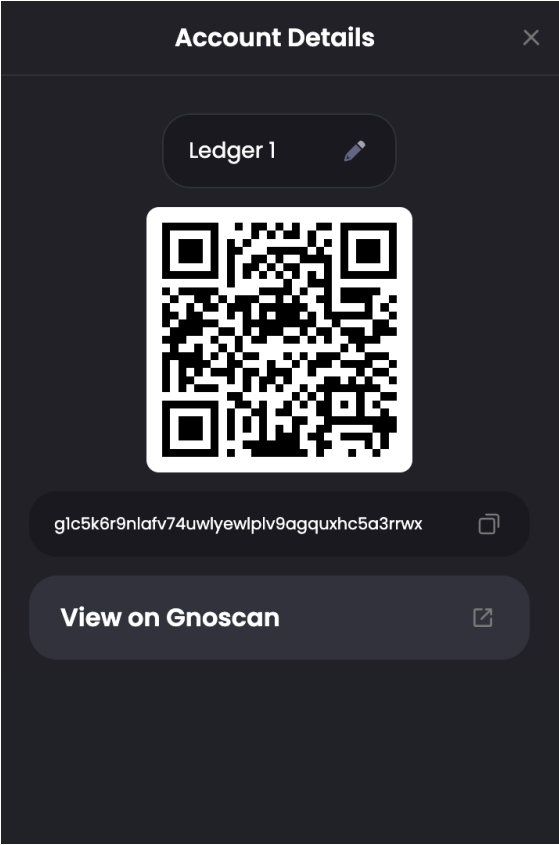


Figure 16: Account Details screen

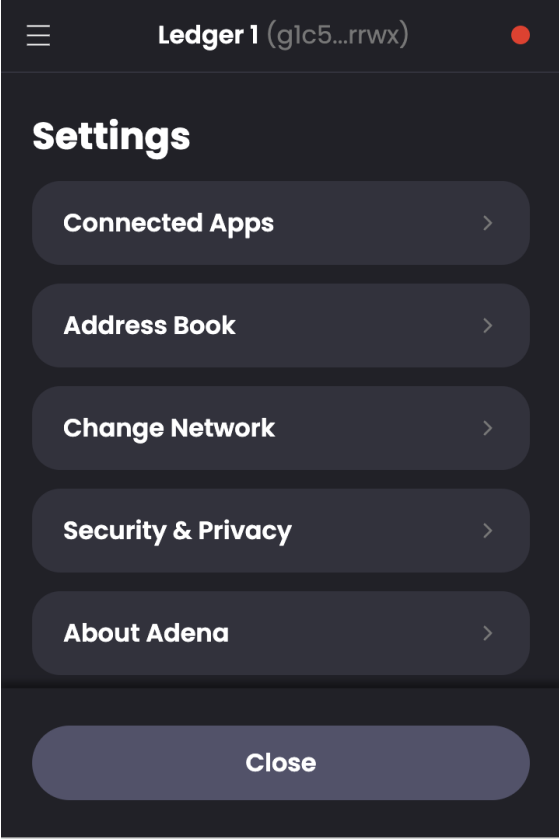


Figure 17: Settings Screen

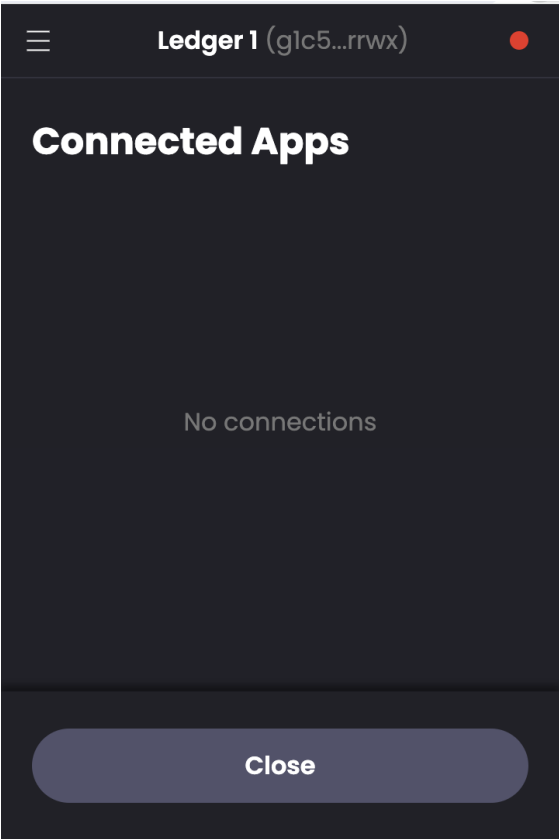


Figure 18: Connected Apps screen

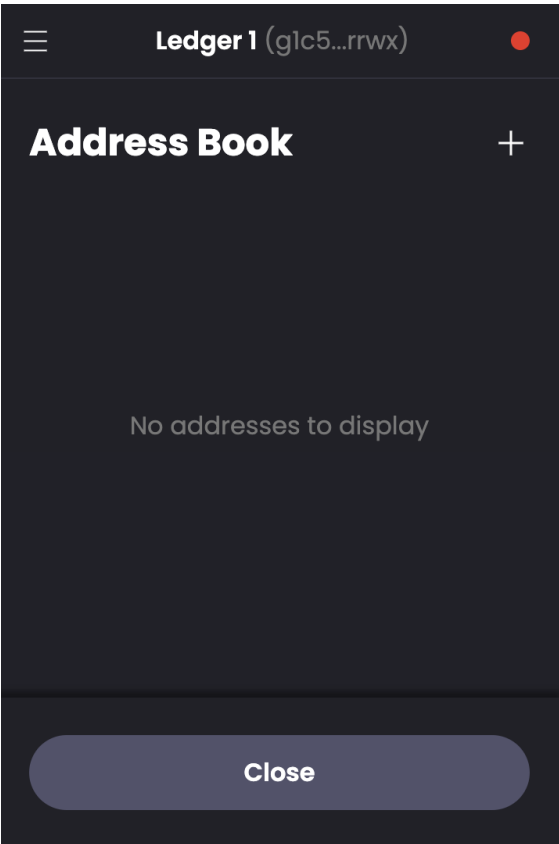


Figure 19: Address Book screen

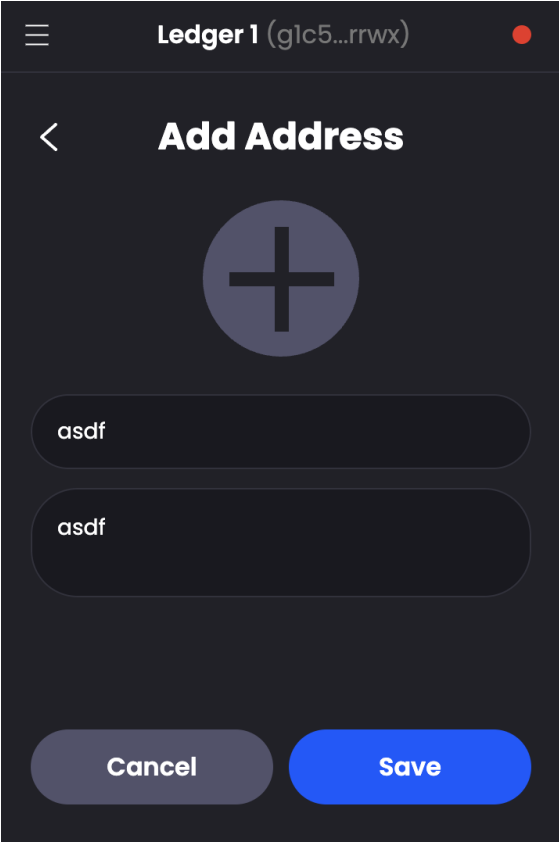


Figure 20: Add Address screen

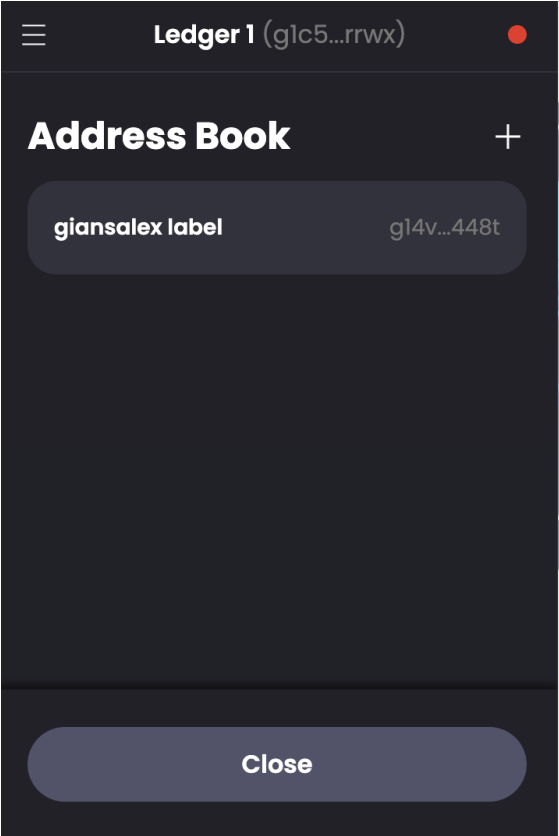


Figure 21: Address Book with one entry

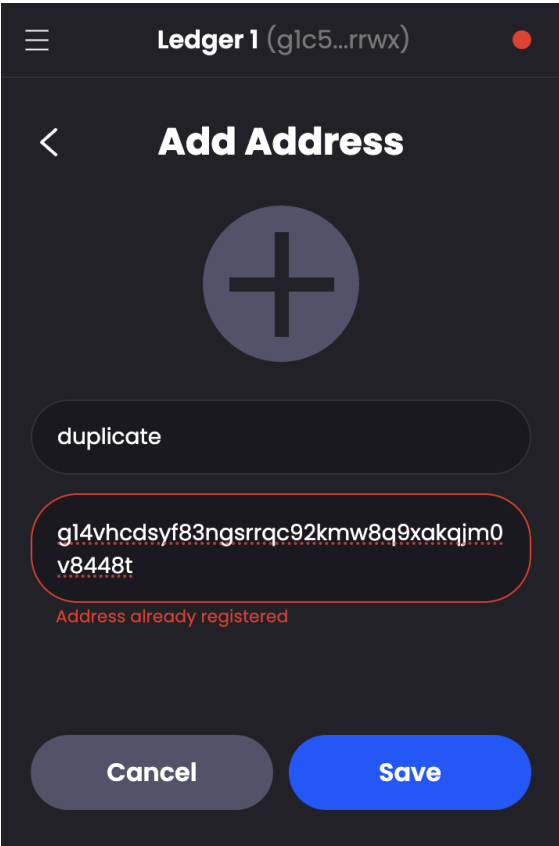


Figure 22: Address Book prevents duplicate entries.

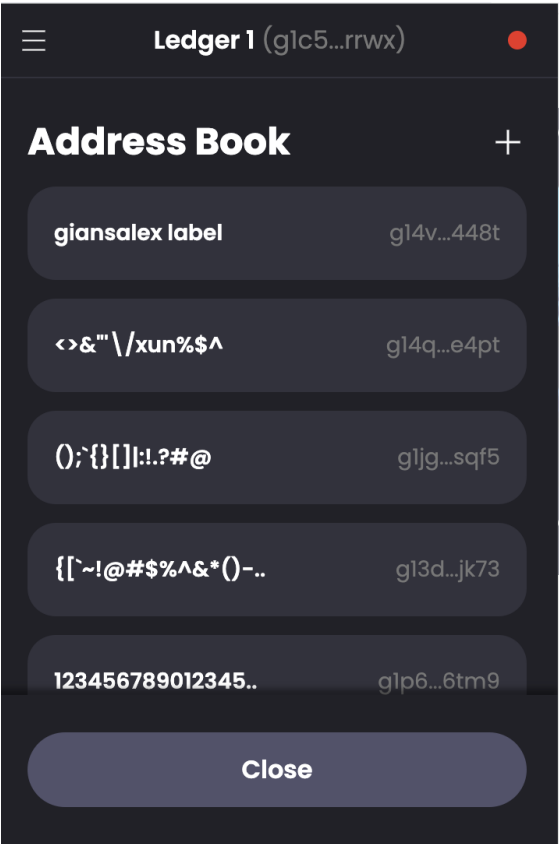


Figure 23: Address Book successfully escapes various special characters.

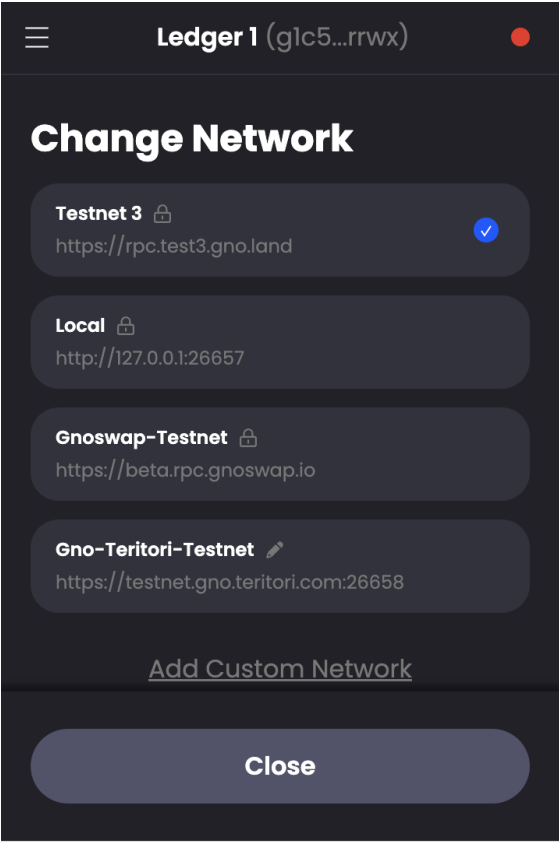


Figure 24: Change Network screen

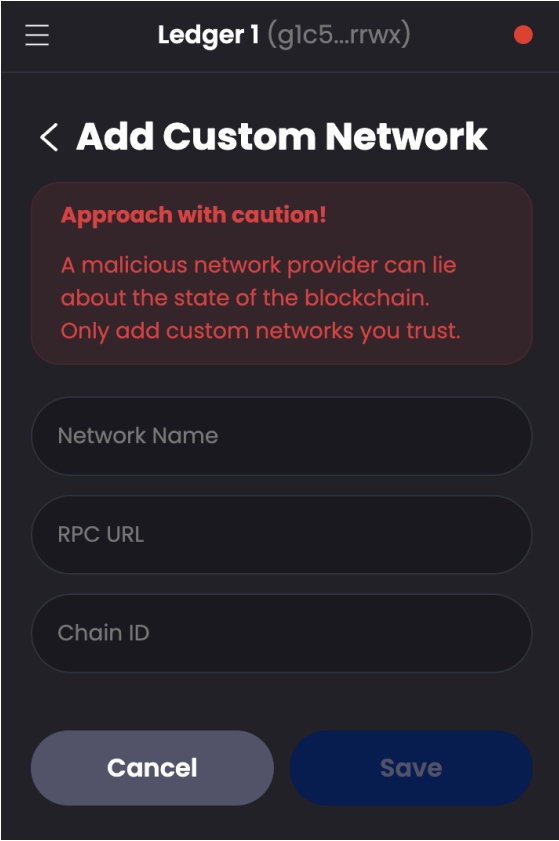


Figure 25: Add Custom Network screen with useful warning message.

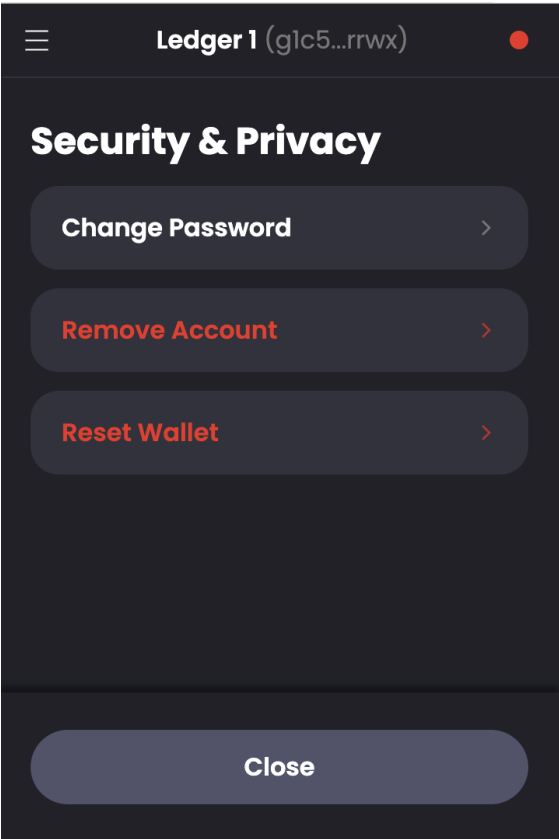


Figure 26: Security & Privacy screen

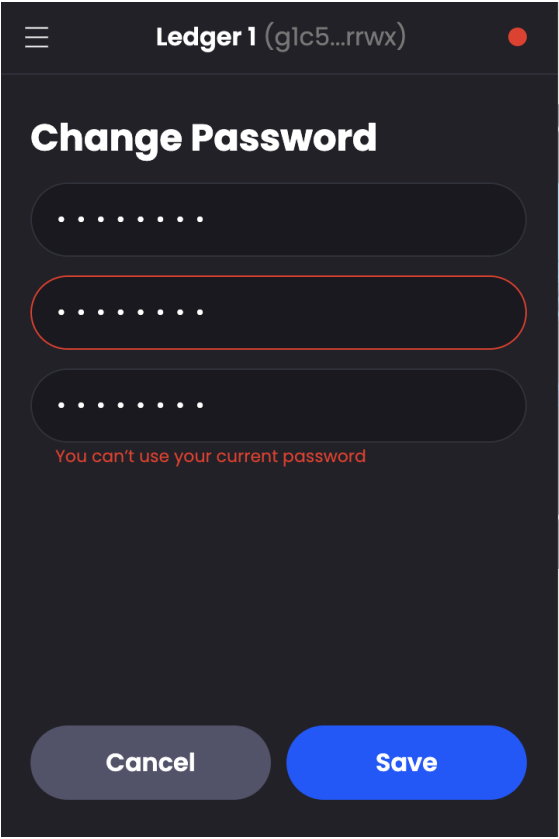


Figure 27: Password change screen prevents password reuse

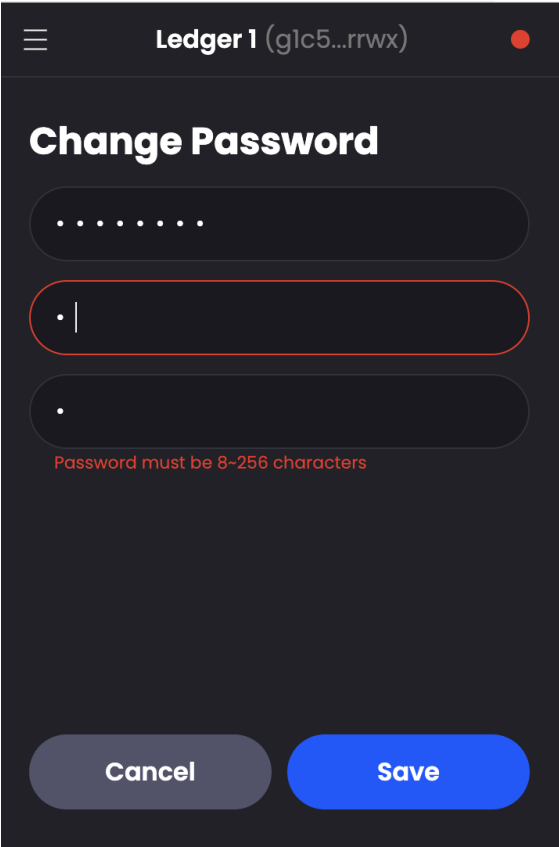


Figure 28: Change Password screen appears to have same password complexity requirements as account creation flow.

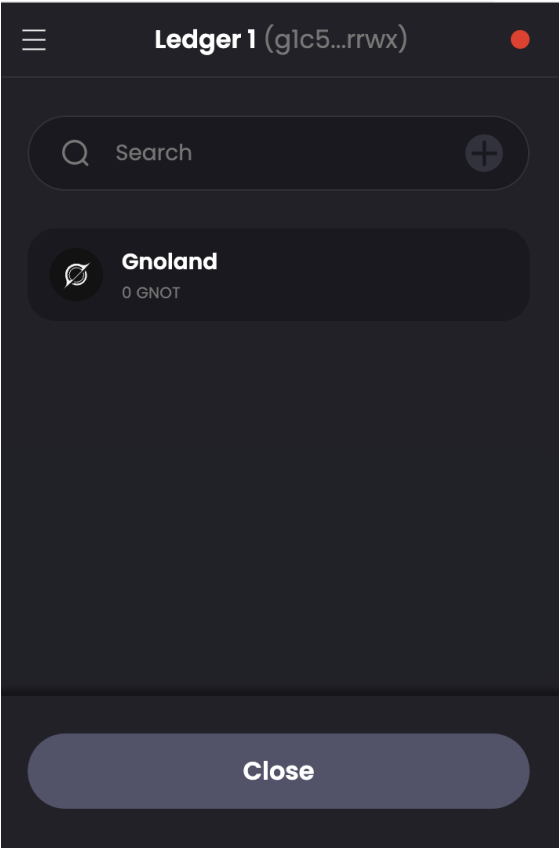


Figure 29: Manage Tokens screen

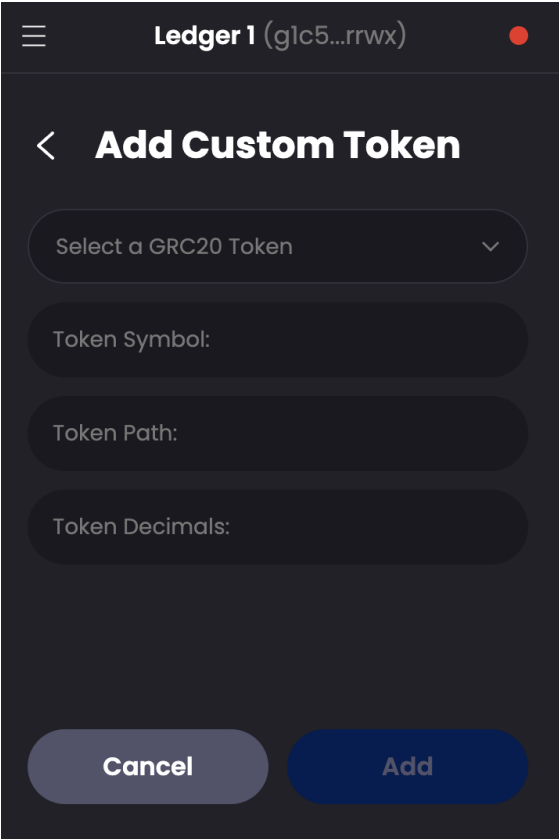


Figure 30: Add Custom Token screen

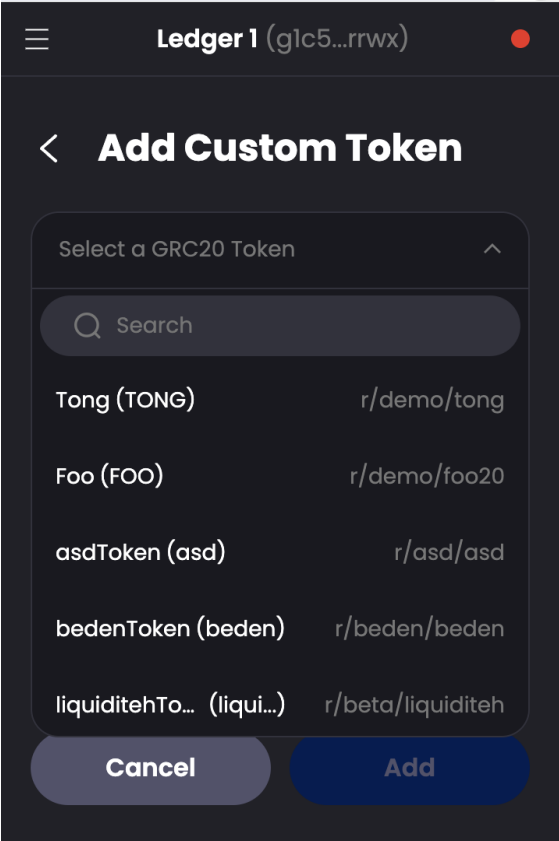


Figure 31: Add Custom Token screen, GRC20 search dropdown

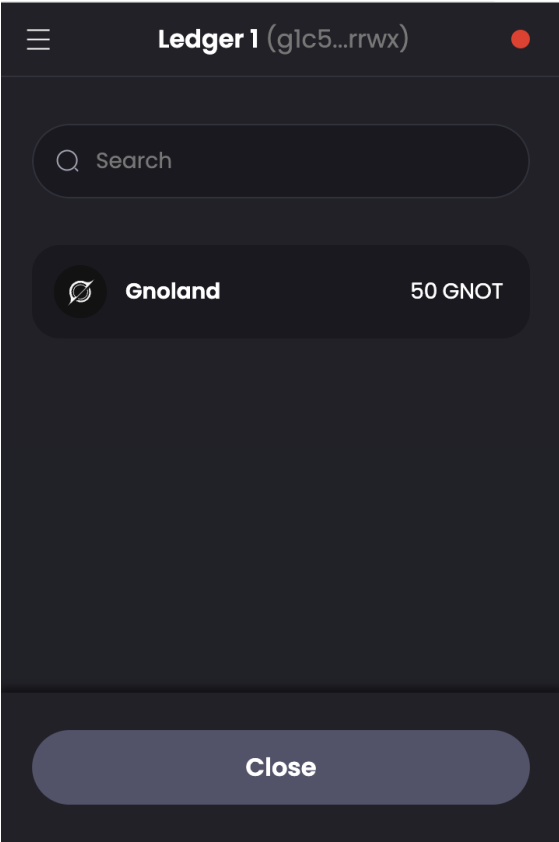


Figure 32: Send screen

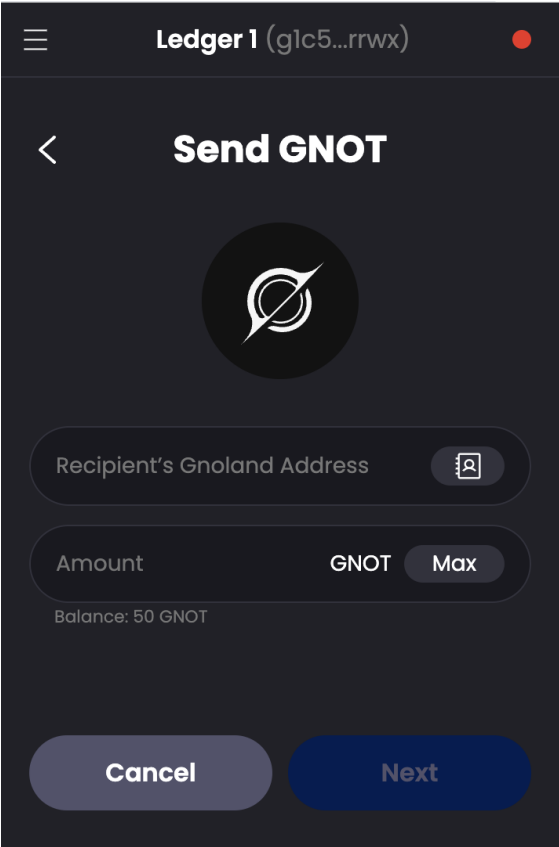


Figure 33: Send GNOT screen

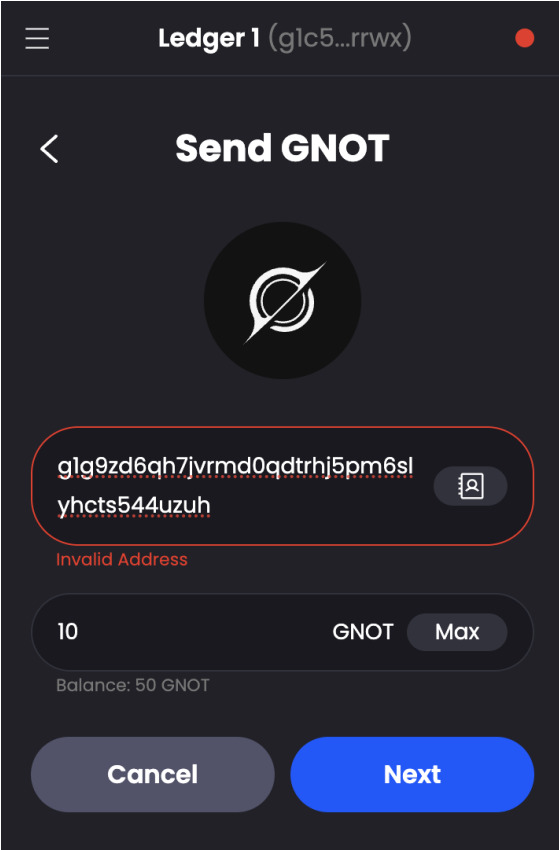


Figure 34: Send screen prevents sending to invalid address (failed checksum)

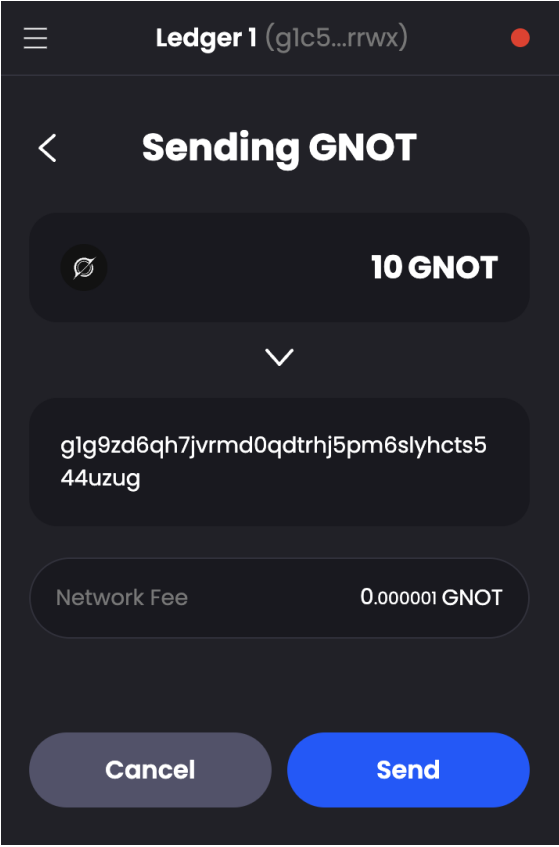


Figure 35: Fee review

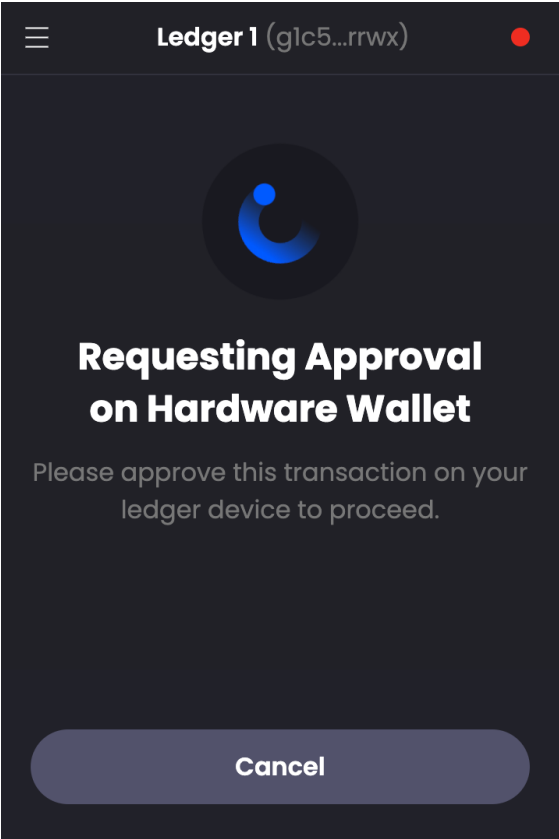


Figure 36: Hardware wallet approval screen

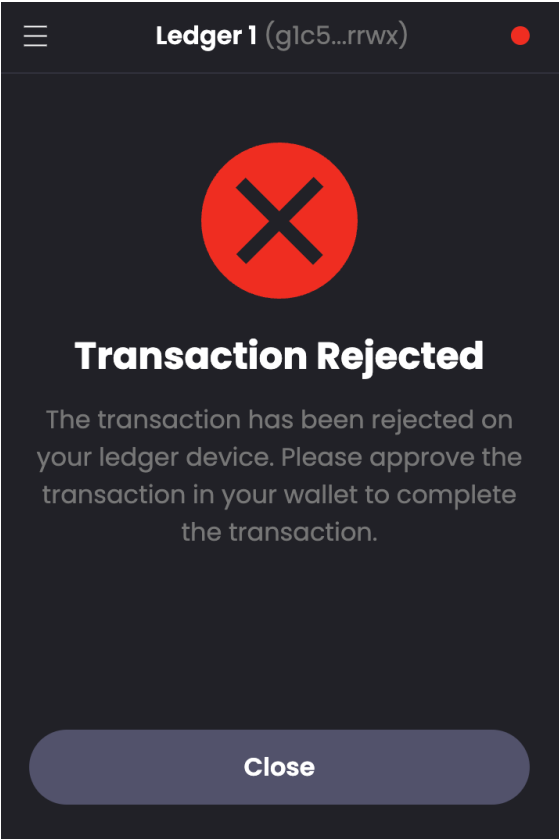


Figure 37: Response when transaction is rejected on Ledger

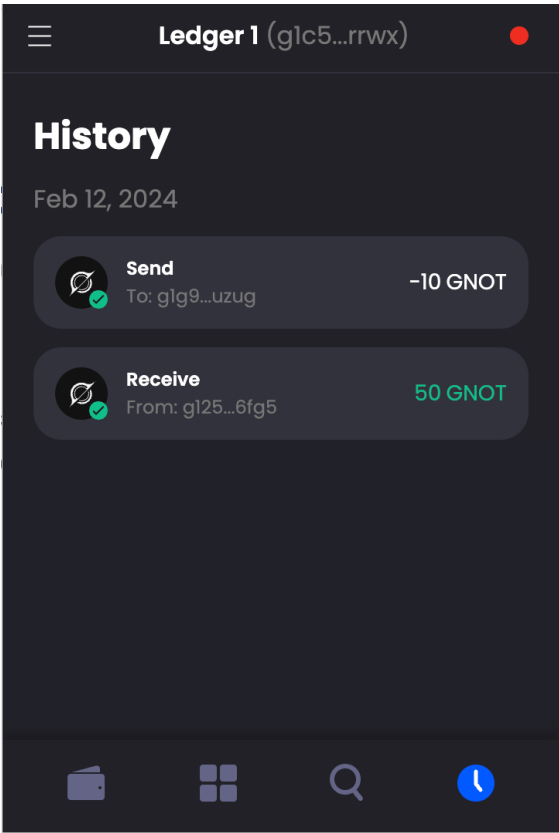


Figure 38: History for sending account

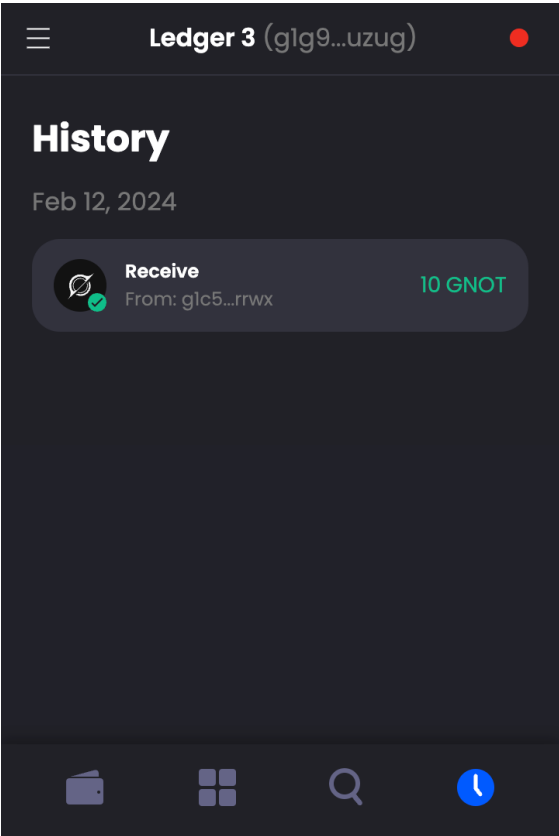
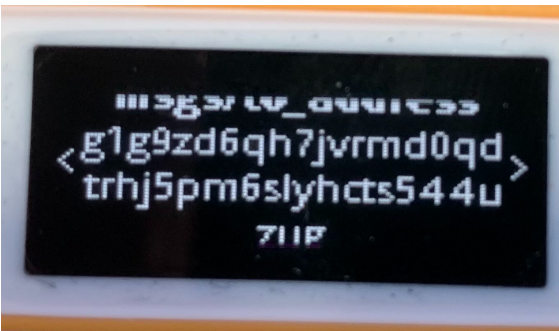
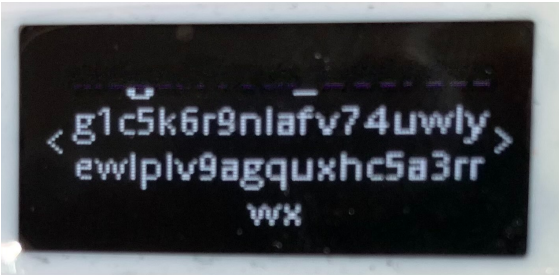
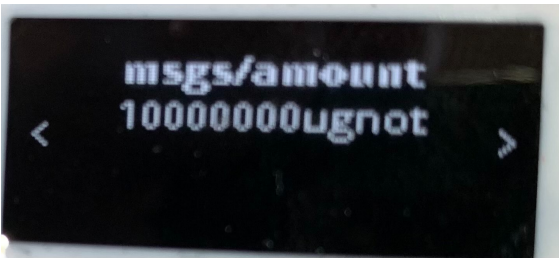
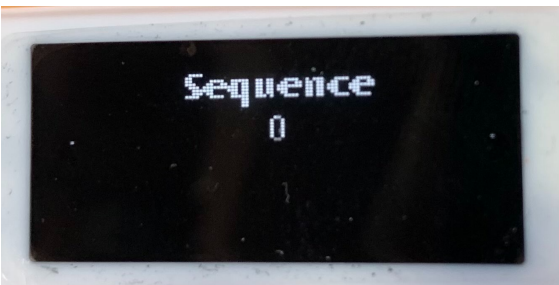
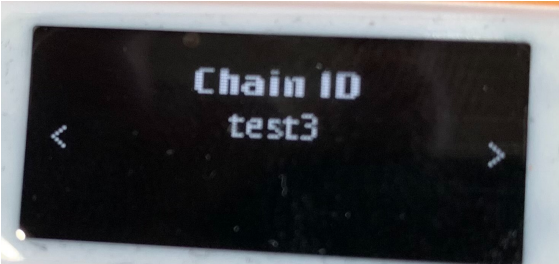


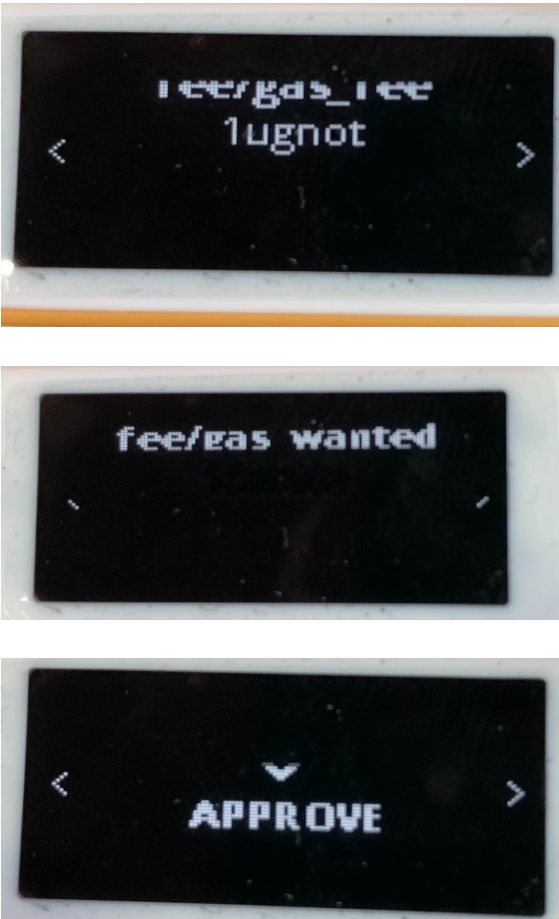
Figure 39: History for receiving account

Appendix III: Ledger device send approval flow

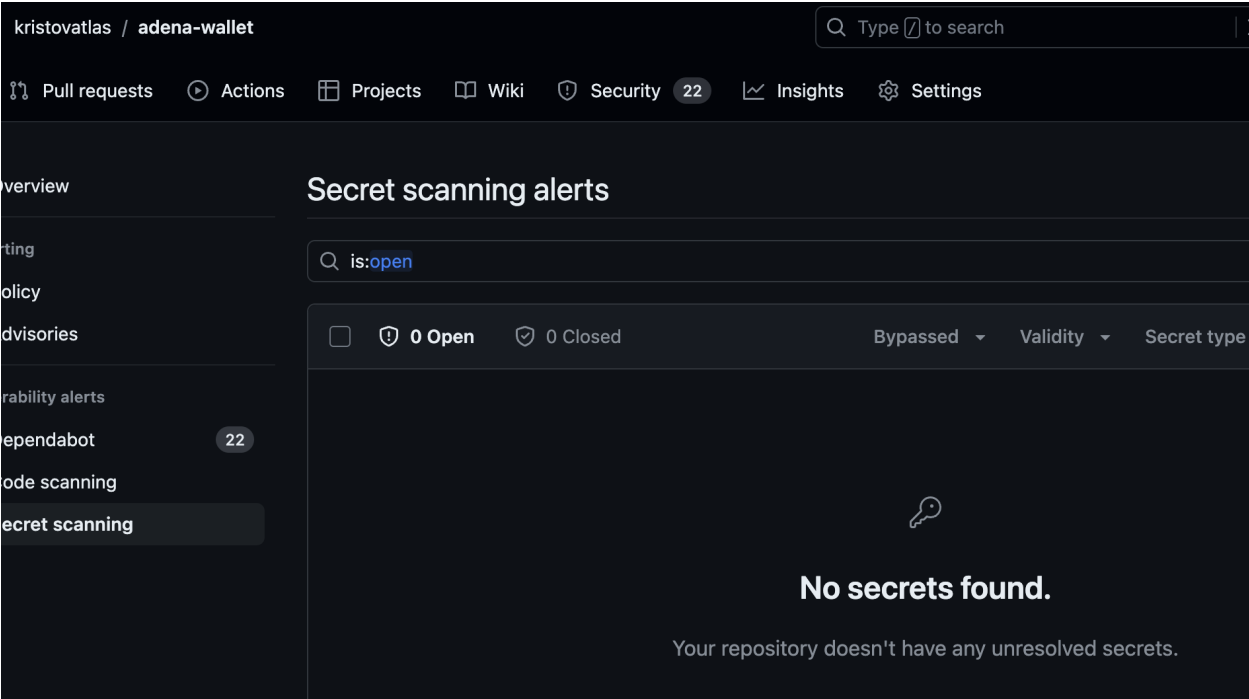
Note: Some pixels not visible due to Ledger screen flicker



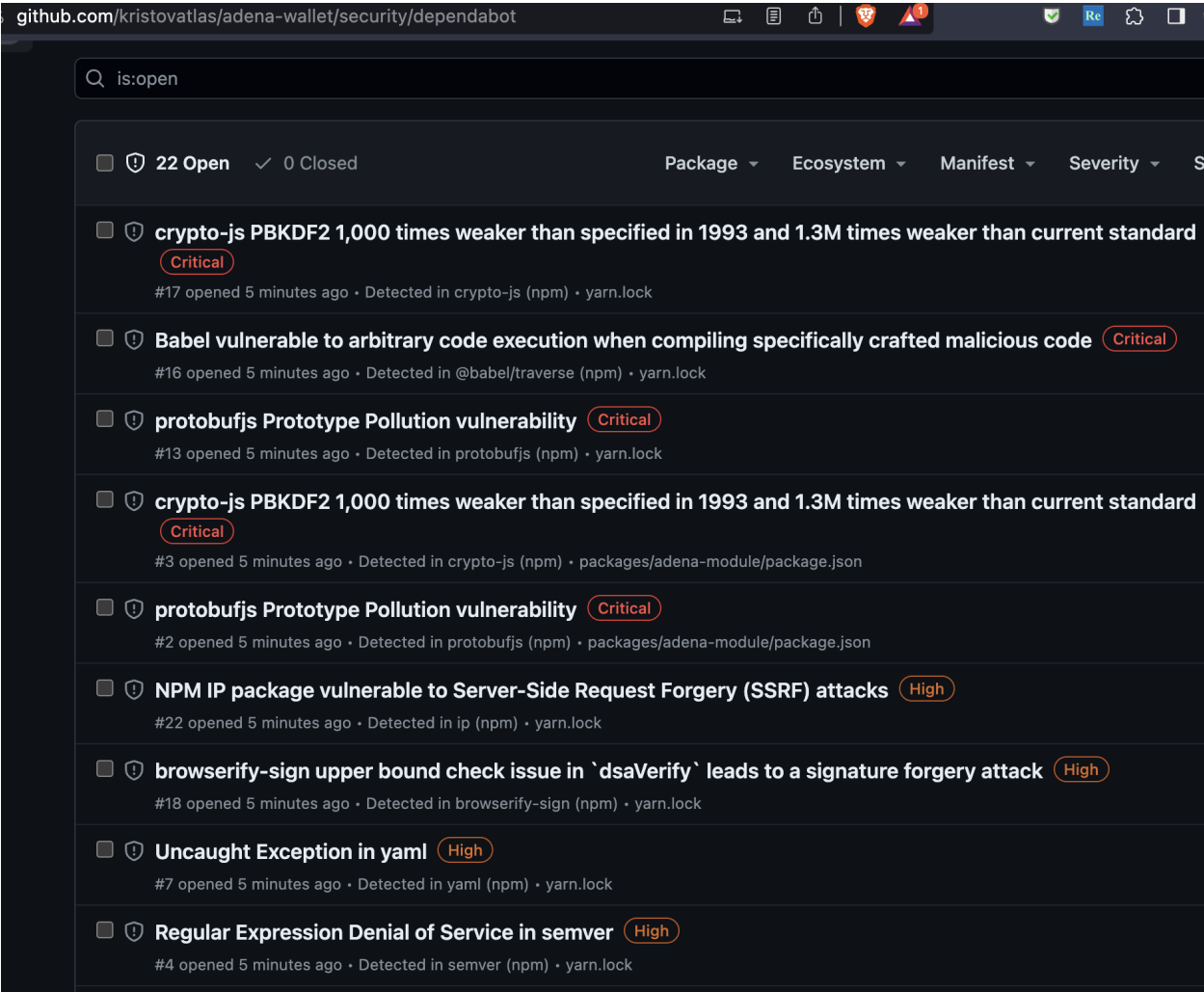




Appendix III: Analysis Artifacts



No secrets were detected in the repo by GitHub's secret scanning tool.



Dependabot detected 22 open dependency vulnerability issues, including 5 Criticals.

- crypto-js has a PBKDF2 issue, but Adena doesn’t use crypto-js for PBKD2 operations
- Other findings were not reviewed during this assessment

Appendix IV: Yarn/NPM Audit Results

```
adena-wallet-1.9.0-rc.0 % yarn npm audit -R
└─ @babel/traverse: 7.21.4
  │ └─ ID: 1095212
  │ └─ Issue: Babel vulnerable to arbitrary code execution when compiling spec
  │ └─ URL: https://github.com/advisories/GHSA-67hx-6x53-jw92
  │ └─ Severity: critical
  │ └─ Vulnerable Versions: <7.23.2
  │ └─ Patched Versions: >=7.23.2
  │ └─ Via: @babel/core, babel-loader, @storybook/react, jest
  └─ Recommendation: Upgrade to version 7.23.2 or later
└─ ip: 2.0.0
  │ └─ ID: 1096460
  │ └─ Issue: NPM IP package vulnerable to Server-Side Request Forgery (SSRF)
  │ └─ URL: https://github.com/advisories/GHSA-78xj-cgh5-2h22
  │ └─ Severity: high
  │ └─ Vulnerable Versions: <=2.0.0
  │ └─ Patched Versions: <0.0.0
  │ └─ Via: jest
  └─ Recommendation: None
└─ semver: 7.4.0
  │ └─ ID: 1095367
  │ └─ Issue: semver vulnerable to Regular Expression Denial of Service
```

```

|   └─ URL: https://github.com/advisories/GHSA-c2qf-rxjj-qqgw
|   └─ Severity: moderate
|   └─ Vulnerable Versions: >=7.0.0 <7.5.2
|   └─ Patched Versions: >=7.5.2
|   └─ Via: @babel/core, babel-loader, @storybook/react, jest
|   └─ Recommendation: Upgrade to version 7.5.2 or later
|
└─ word-wrap: 1.2.3
   └─ ID: 1095091
   └─ Issue: word-wrap vulnerable to Regular Expression Denial of Service
   └─ URL: https://github.com/advisories/GHSA-j8xg-fqg3-53r7
   └─ Severity: moderate
   └─ Vulnerable Versions: <1.2.4
   └─ Patched Versions: >=1.2.4
   └─ Via: eslint, @storybook/react
   └─ Recommendation: Upgrade to version 1.2.4 or later

```

Appendix V: Domains and URLs Accessed

- https[:]//rpc.test3.gno.land/
 - POST / "method":"abci_query" "bank/balances/g1c5k6r..."

Get the balance of an address

- GET /health ⇒ 200 OK {}
- POST / "method":"abci_query" "auth/accounts/g1c5k6r..."

Get information about an address.

⇒

```

{
  "BaseAccount": {
    "address": "g1c5k6r9nlafv74uwlyewlplv9agquxhc5a3rrwx",
    "coins": "399999999ugnot",
    "public_key": {
      "@type": "/tm.PubKeySecp256k1",
      "value": "An86UixPacSCio4IgECsuqreZKHV03XCzt1TxqmxrHx3"
    },
    "account_number": "669142",
    "sequence": "1"
  }
}

```

- An extended list of supported methods is provided here: <https://rpc.test3.gno.land/>

```

Available endpoints:

Endpoints that require arguments:
//rpc.test3.gno.land/abci_info?
//rpc.test3.gno.land/abci_query?path=_&data=_&height=_&prove=_
//rpc.test3.gno.land/block?height=_
//rpc.test3.gno.land/block_results?height=_
//rpc.test3.gno.land/blockchain?minHeight=_&maxHeight=_
//rpc.test3.gno.land/broadcast_tx_async?tx=_
//rpc.test3.gno.land/broadcast_tx_commit?tx=_

```

```
//rpc.test3.gno.land/broadcast_tx_sync?tx=_
//rpc.test3.gno.land/commit?height=_
//rpc.test3.gno.land/consensus_params?height=_
//rpc.test3.gno.land/consensus_state?
//rpc.test3.gno.land/dump_consensus_state?
//rpc.test3.gno.land/genesis?
//rpc.test3.gno.land/health?
//rpc.test3.gno.land/net_info?
//rpc.test3.gno.land/num_unconfirmed_txs?
//rpc.test3.gno.land/status?
//rpc.test3.gno.land/unconfirmed_txs?limit=_
//rpc.test3.gno.land/validators?height=_
```

- <https://api.adena.app/>

- `GET test3/multi_history/g1c5...?from=0&size=20`

Gets a transaction history for a given GNOT address.

⇒

```
{
  "hits": 3,
  "next": false,
  "txs": [
    {
      "height": 264131,
      "date": "2024-02-16 17:42:56",
      "hash": "9R1/+0xY5v1V9rtxTY037FhhveQX470MmCaWumNOCRE=",
      "result": {
        "status": "Success"
      },
      "type": "/bank.MsgSend",
      "msg_num": 1,
      "from": "g1c5k6r9nlafv74uwlyewlplv9agquxhc5a3rrwx",
      "to": "g1g9zd6qh7jvrmd0qdtrhj5pm6slyhcts544uzug",
      "func": "Send",
      "transfer": {
        "amount": "-1000000",
        "denom": "ugnot"
      },
      "fee": {
        "amount": "1",
        "denom": "ugnot"
      }
    },
    {
      "height": 260182,
      "date": "2024-02-13 23:08:32",
      "hash": "D3TmV/keBBGSUGKfE/dubNTzq70Ah1JGSr0d68Bvc68=",
      "result": {
        "status": "Success"
      },
      "type": "/bank.MsgSend",
      "msg_num": 1,
      "from": "g1c5k6r9nlafv74uwlyewlplv9agquxhc5a3rrwx",
      "to": "g1g9zd6qh7jvrmd0qdtrhj5pm6slyhcts544uzug",
      "func": "Send",
      "transfer": {
```



```
        "amount": "-100000000",
        "denom": "ugnot"
    },
    "fee": {
        "amount": "1",
        "denom": "ugnot"
    }
},
{
    "height": 260073,
    "date": "2024-02-13 21:21:47",
    "hash": "Xdvwzjupa4vvXAZRWGNSeXPdHnuYgkn304wCvZ0ItTQ=",
    "result": {
        "status": "Success"
    },
    "type": "/bank.MsgSend",
    "msg_num": 1,
    "from": "g125em6arxsnj49vx35f0n0z34putv5ty3376fg5",
    "to": "g1c5k6r9nlafv74uwlyewlplv9agquxhc5a3rrwx",
    "func": "Receive",
    "transfer": {
        "amount": "500000000",
        "denom": "ugnot"
    },
    "fee": {
        "amount": "1",
        "denom": "ugnot"
    }
}
]
}
```

- <https://raw.githubusercontent.com/onbloc/gno-token-resource/main/>
 - Directory for various static JSON and image assets

Future Areas for Review

- Review findings from static analysis tools including GitHub CodeQL and Solar Qube
- Greater manual analysis of sensitive areas of application, especially `adena-module/src/crypto`, `adena-module/src/wallet/`, `adena-extension/src/common/utills/crypto-utills.ts`, etc.
- Testing with maliciously-crafted GRC20 tokens listed on gnoscan.io
- Re-test Demonic mnemonic vuln; unable to repro during this assessment
- Craft malicious NFTs, particularly those with javascript embedded to search for XSS opportunities.